

연락처 관리 웹 서비스

기술 요구사항 정의서 (TRD)

본 문서는 PRD 및 기능/화면 정의서를 기반으로 시스템 아키텍처, 데이터 모델, API 명세, 예외 처리 메커니즘을 규정하는 개발 설계도입니다.

문서 유형 기술 요구사항 정의서 (Technical Requirements Document)	버전 v1.0 (Baseline)
대상 프레임워크 Python 3.12+ / FastAPI 0.139.0 / SQLAlchemy 2.0.51	데이터베이스 PostgreSQL 16 (Docker 환경)

1. 프로젝트 아키텍처 및 시스템 레이어

본 시스템은 계층형 아키텍처(Layered Architecture)를 채택하여 각 컴포넌트의 책임을 엄격하게 분리합니다. 이를 통해 코드의 가독성, 유지보수성, 테스트 용이성을 극대화합니다.

아키텍처 설계 원칙:

- 표현 계층 (Routers):** HTTP 요청 수집, URL 매핑, 상태 코드 결정을 담당하며 직접적인 DB 구현이나 비즈니스 로직 연산을 배제합니다.
- 비즈니스 로직 계층 (CRUD):** 실제 데이터 조회, 생성, 수정, 삭제 로직 및 사용자 격리 필터링을 수행합니다.
- 데이터 계층 (Models/Schemas):** DB 테이블 매핑 및 Pydantic 기반의 데이터 유효성 검증 규칙을 관리합니다.

1-1. 디렉토리 및 파일 구성

```
contact_app/
|
├── main.py           # 애플리케이션 초기화, 라우터 등록, 정적 파일 및 CORS 설정
├── database.py       # SQLAlchemy 엔진 구성, SessionLocal 팩토리, get_db 의존성 주입 정의
├── models.py         # SQLAlchemy ORM 기반 데이터베이스 테이블 클래스 정의
├── schemas.py        # Pydantic 기반 데이터 유효성 입출력 양식 정의
├── security.py       # pwdlib[argon2] 기반 비밀번호 단방향 해싱 및 검증
├── crud.py           # 비즈니스 로직 및 핵심 DB 데이터 조작 함수
|
├── routers/          # HTTP 엔드포인트 세분화 디렉토리
|   ├── auth.py       # 회원가입, 로그인, 로그아웃, 현재 세션 확인 API
|   ├── contacts.py   # 연락처 정보 관리 (CRUD) API
|   └── categories.py  # 사용자 커스텀 카테고리 관리 API
```

```

|
└─ static/                # 클라이언트 사이드 프론트엔드 정적 리소스
    └─ index.html         # 싱글 페이지 애플리케이션(SPA) 구조 웹 화면
    └─ app.js             # Fetch API 기반 비동기 서버 통신 및 DOM 제어 로직

```

2. 데이터베이스 모델 설계 (ERD 규격)

시스템은 데이터 영속성과 멀티 유저 간 완벽한 격리를 위해 총 4개의 테이블을 관리합니다. 기존 1차 과제의 고정 구조에서 탈피하여, 사용자별 동적 데이터 소유권을 지원하기 위해 외래키(Foreign Key) 관계를 설정합니다.

2-1. 테이블 상세 명세

① users (사용자 계정 테이블)

컬럼명	데이터 타입 (개념)	제약 조건	설명 및 비고
id	Integer	PK, Auto Increment	사용자 고유 일련번호
username	Varchar	UNIQUE, NOT NULL	사용자 로그인 아이디
password_hash	String / Text	NOT NULL	Argon2 알고리즘으로 단방향 해싱된 비밀번호
created_at	Timestamp / DateTime	DEFAULT 현재시각	계정 생성 일시

② sessions (로그인 세션 장부 테이블)

컬럼명	데이터 타입 (개념)	제약 조건	설명 및 비고
session_id	Varchar(64)	PK	secrets.token_hex(32) 기반 무작위 64자 식별 번호
user_id	Integer	FK → users.id, NOT NULL	세션 인증 정보의 소유 사용자 고유 ID
created_at	Timestamp / DateTime	DEFAULT 현재시각	로그인 세션 발급 시각

③ categories (연락처 종류 테이블)

컬럼명	데이터 타입 (개념)	제약 조건	설명 및 비고
id	Integer	PK, Auto Increment	카테고리 고유 일련번호
user_id	Integer	FK → users.id, NOT NULL	카테고리를 소유한 사용자 일련번호 (사용자별 격리)
name	Varchar(10)	NOT NULL	카테고리명 (최소 1자, 최대 10자 입력 제한)
복합 테이블 제약		UNIQUE(user_id, name) : 동일 사용자 내에서 카테고리명 중복 불허	

④ contacts (연락처 정보 테이블)

컬럼명	데이터 타입 (개념)	제약 조건	설명 및 비고
id	Integer	PK, Auto Increment	연락처 고유 일련번호
user_id	Integer	FK → users.id, NOT NULL	연락처 정보를 소유한 사용자 일련번호
category_id	Integer	FK → categories.id, NOT NULL	연락처가 소속된 카테고리 외래키
name	Varchar(5)	NOT NULL	연락처 대상자 이름 (최소 1자, 최대 5자 제한)
phone	Varchar(11)	NOT NULL	전화번호 형식 규격 (010으로 시작하는 총 11자리 숫자)
addr	Text	NULL 허용	주소 데이터 (입력 규칙 검증 배제)
복합 테이블 제약		UNIQUE(user_id, phone) : 동일 사용자 내에서 전화번호 중복 불허	

3. 핵심 기술 및 보안 비기능 명세 (NFR)

3-1. 세션 기반 인증 구현 표준

본 시스템은 추가 외부 의존성을 배제하고 브라우저 고유 기능을 최적화하기 위해 **쿠키 기반 세션 메커니즘**을 채택합니다.

- **세션 토큰 생성:** 파이썬 표준 라이브러리인 `secrets.token_hex(32)` 함수를 사용하여 안전한 암호학적 무작위 문자열(64자리)을 생성 및 발급합니다.
- **쿠키 헤더 전송:** 로그인 성공 시 HTTP 응답의 Set-Cookie 헤더에 `session_id`를 주입합니다. 브라우저는 이를 자동으로 저장하며, 이후 모든 보호 API 요청 시 자동으로 백엔드 서버에 전달합니다.

3-2. Argon2 비밀번호 암호화

보안 규격(NFR-03)에 따라 사용자 비밀번호의 평문(원문) 저장은 엄격히 금지됩니다. FastAPI 공식 문서 추천 규격인 `pwdlib[argon2]` 라이브러리를 사용하여 처리합니다.

- **회원가입 시 해싱 연산:** 사용자 비밀번호 평문을 솔팅(Salting) 기법이 결합된 암호학적 단방향 Argon2 해시 함수를 통해 안전한 문자열로 변경 후 데이터베이스 `password_hash` 필드에 영속화합니다.
- **로그인 시 대조 연산:** 사용자가 전달한 입력 평문 값과 DB 내부의 해시 값을 매치 검증 로직으로 대조하여 인증 처리를 통과시킵니다.

4. 글로벌 예외 및 HTTP 상태 코드 처리 프레임워크

비기능 요구사항 **NFR-01**에 따라 백엔드 서버는 내부 비즈니스 로직 에러나 비정상 예외 상황에서도 절대 `500 Internal Server Error`를 반환하지 않고, 사전에 정의된 상태 코드와 의미 있는 JSON 메시지로 가공하여 전송해야 합니다.

상태 코드	발생 원인 시나리오	반환 데이터 형식 (detail 메시지 구조 예시)
401 Unauthorized	로그인 세션 쿠키 누락 또는 무효화된 세션 ID로 보호 API에 접근한 경우	<code>{"detail": "로그인이 필요한 서비스입니다."}</code>
404 Not Found	조회하려는 리소스(연락처, 카테고리)의 ID가 없거나 타 사용자의 리소스 식별자로 무단 접근을 시도하여 격리 필터에 걸린 경우	<code>{"detail": "존재하지 않거나 접근 권한이 없는 리소스입니다."}</code>
409 Conflict	데이터 일관성 위반 에러 ① 동일 사용자 내 전화번호 중복 ② 카테고리명 중복 ③ 연락처가 소속되어 사용 중인 카테고리 삭제 시도	<code>{"detail": "이미 등록된 전화번호입니다."}</code> 또는 <code>{"detail": "해당 카테고리를 사용하는 연락처가 [3]건 존재하여 삭제할 수 없습니다."}</code>
422 Unprocessable	Pydantic 스키마 검증 실패 (이름 길이 제한 초과, 전화번호 정규식 패턴 미스매칭 등)	FastAPI 내장 검증 오류 레이어가 <code>{"detail": [{"loc": [...], "msg": "..."}]}</code> 형태로 자동 응답 처리

5. REST API 엔드포인트 설계 명세

모든 데이터 CRUD API 엔드포인트는 리소스 명사형 구조와 적합한 HTTP 메서드를 사용해 설계되었습니다. 사용자 인증 의존성 주입이 포함되어 동작합니다.

5-1. 회원 인증 API 영역 (auth)

Method	URL	비즈니스 처리 로직 및 제약 조건	주요 HTTP 상태 코드 반환
POST	/auth/signup	새 계정 등록. 성공 시 해당 유저의 기본 카테고리 시드 데이터 3종(가족, 친구, 기타)을 자동 생성 처리함.	201 Created (성공) 409 Conflict (아이디 중복) 422 Unprocessable Entity
POST	/auth/login	아이디/비밀번호 대조 후 성공 시 64자 세션 발급 및 HTTP 세션 쿠키 주입 반환.	200 OK (성공) 400 Bad Request (인증 정보 불일치)
GET	/auth/me	현재 브라우저에 첨부된 세션 정보를 판별하여 로그인 상태 유무 확인 및 유저 정보 반환.	200 OK (인증 유효) 401 Unauthorized (세션 없음)
POST	/auth/logout	sessions 장부 테이블에서 현재 세션 레코드를 즉시 영구 삭제하여 토큰 무효화 처리.	200 OK (성공) 401 Unauthorized

5-2. 연락처 데이터 API 영역 (contacts)

Method	URL	비즈니스 처리 로직 및 제약 조건	주요 HTTP 상태 코드 반환
POST	/contacts	새 연락처 바인딩 등록. 요청 본문의 category_id가 현재 유저가 소유한 카테고리 범위 내인지 철저히 검증함.	201 Created 401 Unauthorized 404 (권한 없는 카테고리) 409 (동일 유저 내 번호 중복)
GET	/contacts	현재 유저 소유의 연락처 목록 반환. 쿼리 파라미터(name 부분 검색 조건, category_id 필터 조건)를 동적으로 반영함.	200 OK 401 Unauthorized
PATCH	/contacts/{id}	입력된 특정 연락처 레코드 데이터 수정 (이름, 전화번호, 주소, 카테고리 중 변경 대상만 부분 변경 적용).	200 OK 401 Unauthorized 404 (내 연락처 아님) 409 (수정 번호 중복 예러)
DELETE	/contacts/{id}	해당 고유 연락처 데이터를 안전하게 영구 삭제함. 타 유저 아이디로	

Method	URL	비즈니스 처리 로직 및 제약 조건	주요 HTTP 상태 코드 반환
		오접근 시 데이터 유출 방지를 위해 404로 위장 처리함.	200 OK 401 Unauthorized 404 (리소스 소유권 없음)

5-3. 카테고리 관리 API 영역 (categories)

Method	URL	비즈니스 처리 로직 및 제약 조건	주요 HTTP 상태 코드 반환
POST	/categories	사용자 전용 신규 카테고리 종류 등록. (이름 중복 방지 제약)	201 Created 401 Unauthorized 409 (카테고리명 중복)
GET	/categories	현재 로그인 세션 소유자가 생성한 카테고리 전체 목록 조회.	200 OK 401 Unauthorized
PATCH	/categories/{id}	카테고리명 변경 처리. 변경 시 연계된 기존 contacts 테이블 내 연락처들의 카테고리 이름 표기가 UI 상에서 함께 자동 동기화됨.	200 OK 401 Unauthorized 404 (내 카테고리 아님) 409 (이름 중복)
DELETE	/categories/{id}	카테고리 삭제. (무결성 보호 제약): 해당 카테고리에 할당된 기존 연락처 데이터가 단 1건이라도 존재하면 무단 삭제 처리를 강제 거절함.	200 OK 401 Unauthorized 404 (접근 권한 없음) 409 Conflict (연락처 존재함)

6. Pydantic 스키마 유효성 및 데이터 무결성 규칙 규격

시스템에 도달하는 모든 데이터는 `schemas.py` 레이어의 Pydantic 밸리데이터 및 정규식 규칙을 통과해야 인터벌 처리가 개시됩니다.

- **이름 입력 규칙:** `MinLength(1), MaxLength(5)` 제약조건을 부여하여 비정상적으로 길거나 짧은 데이터의 유입을 물리적으로 차단합니다. (카테고리 이름의 경우 `MaxLength(10)` 적용)
- **전화번호 포맷 규칙:** 파이썬 정규표현식 구조인 `^010\d{8}$` 패턴을 사용하여 반드시 010으로 완벽히 시작하고 뒤이어 정확히 8자리의 숫자가 등장하는 총 11자리의 규격화된 텍스트 양식만 수용 처리합니다.